

Access Control Policy

Policy ID: HH-ISMS-02 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

1. Purpose

A hospital system that lets the wrong person in — or keeps the right person in after they leave — fails patients. We need:

- **Authentication:** proof that the person is who they say they are.
- **Authorization:** proof that the person is allowed to do what they're trying to do.
- **Accountability:** an audit trail that ties actions to identities.

Without all three, we cannot answer “who deleted this patient record?” or “who accessed this salary slip at 2 AM?”. This policy defines how we grant, manage, and revoke access across every Haritha touchpoint.

The 2026-08-29 DB password drift incident (LEARNINGS #154) is a reminder: even the most basic access primitive — knowing the current prod DB password — can silently rot if we don't verify it. This policy treats credentials as living state, not constants.

2. Scope

Every identity-bearing system:

- **ERPNext / haritha_hospital app.** Production (pberpprod), Dev (pberpdev), QA (pberpqa). Each has its own tabUser table.
- **MariaDB.** erp-prod-db-1, erp-dev-db-1, erp-qa-db-1 (VPS), plus erpdev-mariadb-1 on Venkat's dev-erp box.
- **GitHub.** venkat-narasimha/haritha-hospitals (push), read-only collaborators.
- **VPS host (vps-3248b821).** User vijay (admin), SSH key from /root/.openclaw/ssh_key.
- **Container orchestration.** docker group membership, docker exec privileges.
- **Offsite backup.** venkat@135.125.196.35, SSH key from /root/.openclaw/venkat_vps_key.
- **Frappe Bench + scheduler.** Backend containers expose bench commands; access is via docker exec on the host.
- **DuckDNS.** Dynamic DNS update token (currently in frappeclaw compose env).
- **Let's Encrypt.** Cert issuance via certbot; renewal is automated.

3. Policy Statement

3.1 Principles

1. **Least privilege.** New users get the minimum role set that lets them do their job. Default for new app users: Employee role (read own records + submit attendance). Default for new DB users: no account (use root from inside the container network).
2. **Role-Based Access Control (RBAC).** Permissions are grouped into Frappe roles, then users are assigned roles. No per-document ACL hacks. Roles are defined in apps/haritha_hospital/haritha_hospital/hooks.py and exported as fixtures.
3. **No shared accounts.** Every human has their own tabUser. “Reception shift account” is forbidden; create per-user accounts instead. Service accounts (cron, integrations) are named after their function (nightly-backup, duckdns-updater), not shared.
4. **Defense in depth.** Two controls must fail before data leaks — e.g., MFA + VPN, or SSH key + IP allowlist, or RBAC role + row-level filter.

3.2 Authentication

1. **Passwords (Frappe app users).**
 - Minimum 12 characters.
 - Mix of upper + lower + digit + symbol (Frappe enforces this server-side).
 - Rotation every 90 days. Frappe's password expiry setting enforces this.
 - No reuse across Haritha and personal accounts.
2. **Multi-factor authentication (MFA).**
 - **Required** for any user with System Manager or Administrator role on production.
 - **Required** for any user with ALL role in Frappe.
 - TOTP preferred over SMS (no SMS delivery fee, no SIM swap risk).
3. **Database credentials.**
 - Stored in **container environment variables** (MYSQL_ROOT_PASSWORD), not in files on disk. LEARNINGS #154 documents why hardcoded values in MEMORY.md went stale.
 - Quarterly verification: `docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD` must match the access register entry.
4. **SSH keys.**
 - ed25519 or 4096-bit RSA. No DSA, no 1024-bit RSA.
 - Passphrase-protected at rest. `ssh-agent` is fine for session use; raw key on disk without passphrase is forbidden.
 - Rotation annually. Old key remains valid for 7 days as overlap, then is revoked.
5. **GitHub.** Personal access tokens are fine for HTTPS; SSH key (the same `/root/.openclaw/ssh_key`) is preferred. Token rotation annually; tokens stored in OS keychain or container env, never in repo.
6. **API tokens.** Generated per-user in Frappe, scoped to specific API endpoints, rotated annually. Service-account tokens are rotated on every personnel change.

3.3 Authorization

1. **Production write access.** Limited to users with System Manager role. Currently: Venkat (only). All INSERT/UPDATE/DELETE against `tab*` tables by non-System-Managers go through standard form submissions (audit-logged).
2. **Direct DB write access.** Read-only SELECT is permitted for analysts via a dedicated DB user (`haritha_ro`). All INSERT/UPDATE/DELETE require explicit elevation, which is logged in `/var/log/erp-prod-db-access.log`.
3. **SSH to VPS.** `vijay` user has `sudo`. No other SSH users. Root login via SSH is disabled (`PermitRootLogin no` in `/etc/ssh/sshd_config`).
4. **Container exec.** Anyone with `docker` group membership can `docker exec` any container. Membership is `vijay` only. No passwordless `docker` for non-admins.
5. **Git push.** Direct push to `main` is restricted to Venkat. All other contributors PR from feature branches; CI runs lint + `migrate-dry-run`.

3.4 Lifecycle

1. **Provisioning.** New user request → Venkat creates `tabUser` with minimum role + sets password expiry + enrolls in MFA. Entry logged in `docs/phase6/09-compliance/access-register.md`.
2. **Modification.** Role changes require Venkat approval. Role additions/removals audited.
3. **Deprovisioning.** When a user leaves:
 - `tabUser.enabled = 0` within 1 hour of departure notification.
 - `tabUser.new_password` rotated (in case of stale session).
 - Personal SSH keys removed from `~/ssh/authorized_keys` on VPS + offsite.
 - Personal API tokens revoked in Frappe.
 - Entry marked `INACTIVE` in access register.

4. **Quarterly review.** Venkat reviews the full access register. Anyone without a documented business need is removed.
5. **Failed login handling.** After 5 failed logins in 10 minutes, the account is locked for 30 minutes. Lockouts are alerted (admin reviews daily). Repeated lockouts for the same account trigger SEV-3 review.

3a. Current State (as of 2026-08-29)

Concrete inventory of who/what currently has access, what works, and what gaps remain.

Who has access TODAY

Identity	Surface	Scope	MFA	Notes
Venkat Narasimha	tabUser on pberpprod, pberpdev, pberpqa	System Manager + Administrator (prod); System Manager (dev/qa)	TOTP enrolled	Owner / sole admin
Processbricks admin	tabUser on pberpdev only	System Manager (dev), read on others	TOTP enrolled (pending)	Operational handoff role
Vijaya (reception)	tabUser on pberpprod	Employee + Healthcare Receptionist (custom)	Not enrolled	Password-only for now (gap)
6 nurses (shift-A..C)	tabUser per nurse on pberpprod	Employee + Nurse (custom)	Not enrolled	Password-only (gap; see Edge Case 2 in 01)
HR officer	tabUser on pberpprod	HR Manager + HR User	TOTP enrolled	PHI-adjacent role
nightly-backup	service account (no tabUser)	runs bench backup via cron	n/a (no UI)	Container env creds
duckdns-updater	service account (no tabUser)	updates *.duckdns.org A record	n/a (no UI)	Container env token
haritha_ro	MariaDB user (read-only)	SELECT on prod DB	n/a (DB-level)	For analyst queries
vijay (Unix)	sudo	full host + docker exec	SSH key only	Backup orchestration + admin
venkat (Unix, offsite)	sudo on offsite VPS	receives rsync	SSH key only	Offsite data surface

What is WORKING

- **TOTP MFA enforcement on System Manager role** is live and blocking non-MFA logins for that role.
- **Per-environment tabUser separation.** pberpprod users are not pberpdev users. Production admin (Venkat) has separate credentials from dev admin.

- **Container env var pattern for DB passwords.** Since the LEARNINGS #154 incident, all production DB passwords live ONLY in container env. MEMORY.md has a CAUTION: literals may be stale banner. Quarterly verification is in the runbook.
- **SSH key separation per host.** /root/.openclaw/ssh_key for the main VPS, /root/.openclaw/venkat_vps_key for offsite. A compromise of one does not equal compromise of the other (LEARNINGS 2026-05-23 batch).
- **PermitRootLogin no** on both VPSes. Root can only be reached via sudo from vi-jay/venkat.
- **No password SSH.** Both VPSes accept key-only auth.
- **Frappe role separation.** Employees see only their own records by default (row-level filter via tabEmployee linkage). HR sees HR-scope. System Manager sees all.

Known GAPS

1. **MFA coverage incomplete.** Only System Manager / Administrator are MFA-enrolled. Front-desk nurses, reception, and HR officer who handle PHI are password-only. Risk: a phished password is enough to read PHI. Tracked in 01-info-security §9 checklist.
2. **No valid_upto field on tabHasRole** — elevated roles do not auto-expire; revocation is a manual step that requires a calendar reminder. LEARNINGS trail has “future improvement” notes for this.
3. **No SCIM / SSO.** Adding a new employee requires a manual Venkat action. Future: integrate with whatever HRIS we eventually use.
4. **No formal access-register.md file.** The register exists in 09-compliance/access-register.md as a stub; the canonical source is Venkat’s notes. Will be formalized next batch.
5. **No DB query audit log per haritha_ro user.** The read-only DB user has SELECT but no per-query log. A future improvement is general_log for a sliding 7-day window.
6. **Service accounts are technically 'no MFA'.** They can’t enroll (no human to scan the QR). Mitigated by: scope (single endpoint), network (container-internal), and storage (env-var-only).

These gaps are documented so a future reader knows what the policy claims vs what is currently enforced.

3b. Concrete Examples (Haritha history)

Real access-control incidents and near-misses that shaped this policy.

Example 1 — 2026-08-29 prod DB password drift / 401 incident (LEARNINGS #154)

- **What happened.** Production DB login returned 401 when Venkat tried to run an emergency query. The password in MEMORY.md was stale.
- **Root cause.** Two old literals (9b35e477b5ede662, eGtsatXqERFAvW4M) from a previous ops session were never re-verified against the container env.
- **Response.** Canonical read pattern (LEARNINGS #154): `docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD`. Quarterly verification added to §5. MEMORY.md gets a permanent CAUTION: literals may be stale banner.
- **Policy lesson.** A password you can’t re-verify from the canonical source isn’t a credential — it’s folklore. This policy §3.2.3 (“Database credentials”) now mandates quarterly proof-from-env. Future: every credential in MEMORY.md gets a <VERIFY-VIA: command> annotation.

Example 2 — 2026-08-29 gunicorn --preload outage (LEARNINGS #153) — access-control angle

- **What happened.** After `bench install-app haritha_hospital`, all HTTP requests returned 500. Both prod and dev down.
- **Root cause.** Gunicorn freezes `sys.path` at startup; new apps need a container restart. `bench restart` doesn't restart gunicorn.
- **Response.** `docker restart erp-{env}-backend-1` in parallel for both envs.
- **Access-control lesson.** The deployment process did not have an explicit "container restart required after install-app" gate. A benign-looking deployment (`bench install-app exit 0`) was actually a partial deployment that broke the auth boundary. §3.4 Lifecycle now mandates a post-install restart as part of the deployment checklist (`../04-runbooks/04.1-deployment.md`).

Example 3 — 2026-08-19 backup recovery + cron race audit (LEARNINGS 2026-08-18 batch)

- **What happened.** During the 2026-08-18 cron-race-recovery session, the on-call admin had to act as a temporary System Manager on prod to debug the silent backup failures. He elevated himself, ran queries, and notified Venkat on contact.
- **Root cause.** Emergency-access flow worked as designed (`elevate + log + notify`). What didn't work was the *speed of de-elevation*: he forgot to drop the role once Venkat came online. Role lingered for 11 hours until the next daily ops review caught it.
- **Response.** Added explicit "drop role" step to the emergency-access checklist in `../04-runbooks/04.4-incident-response.md`. Calendar reminder added.
- **Policy lesson.** "Temporary" roles are sticky. Without a hard expiry + reminder, they live forever. This is exactly what §3.4 Deprovisioning + Edge Case 6 (Personnel unavailable) exist to address.

Example 4 — 2026-08-11 Roster delete-after-submit (LEARNINGS 2026-08-11 phase6/04)

- **What happened.** A test Roster entry was deleted immediately after submit (Frappe framework default for some HRMS docs).
- **Root cause.** Default behavior was inherited by `haritha_hospital`; no override.
- **Response.** Test scripts now query `tabVersion` (audit log) for soft-deleted docs; persisted sample data used for chart-config tests.
- **Access-control lesson.** Audit logs are an access-control primitive — they answer "who touched this and when". Without `tabVersion` populated, you cannot investigate a suspect change. §3.4 explicitly requires that all elevated-window actions be auditable; this example shows the principle applies even to routine test data.

Example 5 — 2026-05-23 SSH key compromise + backup key handling (LEARNINGS)

- **What happened (hypothetical drill).** Venkat's laptop compromised. Primary SSH key for the main VPS was on it.
- **Root cause.** Single-machine single-key infrastructure would have collapsed entirely.
- **Response.** Documented key-separation: primary key on Venkat's machine, offsite key on a different machine. Compromise of one does not equal compromise of the other.
- **Policy lesson.** This is the reason §3.2.4 mandates per-host SSH keys with rotation. The "blast radius" of a key compromise is bounded by what the key can authenticate to.

Example 6 — 2026-08-15 Git commit identity drift (LEARNINGS MEMORY rule)

- **What happened.** Three identities showed up in pberp_hospital and pberpqa-hospital-demo repos: erpclaw, claude, and venkat-narasimha. Some agents committed as themselves, breaking the audit trail.
- **Root cause.** No enforced git identity on container + VPS; agents used defaults.
- **Response.** `git config --global user.name venkat-narasimha && git config --global user.email srivenkatnarasimha@gmail.com` now runs on container bootstrap and VPS bootstrap. Non-negotiable.
- **Access-control lesson.** Audit trails need identity consistency. If `git log` shows three authors for the same logical user, you cannot answer “who made this change?”. §4 Responsibilities now explicitly lists commit identity as Venkat’s concern, with PA responsible for enforcement.

4. Responsibilities

Role	Responsibilities
Venkat (Owner)	Approves all role grants beyond defaults. Quarterly access reviews. Final escalation on account compromise. Owns the access register.
Processbricks admin	Implements Frappe role/permission changes (hooks.py + custom app). Monitors failed-login alerts. Verifies DB passwords quarterly.
Users	Protect their own credentials. Don’t share. Don’t bypass MFA. Don’t leave sessions unattended on shared workstations. Report compromise within 1 hour.
Vendors	Use scoped service accounts, never their personal credentials. Rotate credentials on personnel change.

5. Compliance Measurement

Check	Frequency	Owner	Source of truth
Access register reconciled to tabUser	Quarterly	Venkat	tabUser table
DB passwords verified against container env	Quarterly	admin	<code>docker exec ... printenv MYSQL_ROOT_PASSWORD</code>
Failed login rate	Daily review	admin	<code>frappe-bench/logs/*.log</code>
Account lockouts	Daily review	admin	tabUser lock flags
SSH key age	Annually	Venkat	key creation timestamp
API token age	Annually	Venkat	tabAPI Token table
Users with System Manager role	Monthly	Venkat	tabHasRole

Check	Frequency	Owner	Source of truth
GitHub collaborators	Quarterly	Venkat	repo settings

KPI target: zero standing privileges beyond what's documented in the access register. Zero plaintext credentials outside container envs.

6. Exceptions

Temporary elevated access (e.g., "I need System Manager for 4 hours to fix a payroll bug"):

1. Requester files a ticket naming the role, the reason, the time window, and the audit log they'll generate.
2. Venkat grants the role in Frappe (manual SQL or UI).
3. The role is **scheduled to auto-expire** — Frappe has no native TTL, so we use a calendar reminder + manual revocation. (Future: implement `valid_upto` field on `tabHasRole`; tracked as future improvement.)
4. All actions during the elevated window are logged and reviewed at the next access review.
5. Exceptions for production DB write access: the same flow, plus a post-window audit of every INSERT/UPDATE/DELETE against the affected tables.

Emergency access (e.g., production is down and Venkat is unreachable): the on-call admin may elevate themselves, log the action in `/var/log/erp-emergency-access.log` with a written justification, and notify Venkat within 1 hour of regaining contact. Post-incident review covers prevention.

6a. Edge Cases & Decision Matrix

Specific scenarios that test the policy's boundaries. Each entry includes the trigger, the decision, and the rationale.

Edge case 1 — Dev needs temporary System Manager on prod to debug a payroll bug

- **Trigger.** PA needs to inspect (not modify) `tabSalary Slip` rows for a specific employee as part of a payroll investigation. PA's existing role is System Manager on dev only.
- **Decision matrix.**

Action	Allowed?	Why
Grant temporary System Manager on prod via Frappe UI	YES (with Venkat approval)	Read + script access required; elevation is auditable
Use dev DB to reproduce, query prod via API only	YES (no elevation needed)	Preferred path; prod DB should not be touched if dev repro works
SSH to prod, run bench console, query <code>tabSalary Slip</code> directly	CONDITIONAL	Allowed only with explicit ticket + post-query audit log review
Copy <code>tabSalary Slip</code> rows to local laptop for analysis	NO	§3.5 of 01 — no prod data on personal devices

- **Default action.** Reproduce on dev first. If repro fails, request elevation with a ticket that names the bug ID, the time window ($\leq 4h$), and the audit log to be reviewed. Calendar reminder set for de-elevation.

Edge case 2 — Front desk nurse is unavailable, replacement needs ad-hoc access

- **Trigger.** A nurse calls in sick. A floating nurse from another ward needs to cover the front desk for 8 hours. She has her own `tabUser` with Employee + Nurse roles, but the front desk has additional custom permissions (e.g., patient check-in).
- **Decision matrix.**

Action	Allowed?	Why
Use the sick nurse's <code>tabUser</code> (shared password)	NO	§3.1.3 — no shared accounts; audit trail would show sick nurse doing the work
Grant floating nurse the missing custom role for 8h, then auto-revoke	YES	Time-boxed elevation, auditable, minimal blast radius
Grant floating nurse System Manager for 8h as a shortcut	NO	Massively over-privileged; not least-privilege
Add a "Front Desk Shift Coverage" role profile that both nurses can hold	YES (preferred)	Permanent role grant; no temporary elevation; both nurses have it always

- **Default action.** Add the floating nurse to the existing Front Desk Shift Coverage role profile. If such a role profile doesn't exist yet, request its creation from Venkat (1-day turnaround). Never share credentials.

Edge case 3 — HR officer needs to bulk-import employee records

- **Trigger.** Onboarding 12 new employees at start of month. HR needs to bulk-insert `tabEmployee` rows from a CSV.
- **Decision matrix.**

Action	Allowed?	Why
Data Import Tool (Frappe framework)	YES	Audit-logged, validates against <code>DocType</code> , supports dry-run
Direct SQL <code>INSERT INTO tabEmployee</code>	NO	Bypasses all framework validation; not auditable as a user action
<code>bench console</code> with a Python loop calling <code>.insert()</code>	CONDITIONAL	Allowed if script is checked into repo + ticket references it
CSV emailed to Venkat for manual import	NO	CSV is Confidential (PII); email is unencrypted

- **Default action.** Use the Data Import Tool. Pre-validate on a single row first. Capture the import ID for audit.

Edge case 4 — A patient's family member requests their medical record

- **Trigger.** Patient (or legal representative) requests a copy of `tabPatient` Medical Record for personal use or for a second-opinion consultation.
- **Decision matrix.**

Requester	Allowed to receive?	Process
Patient themselves (verified identity)	YES	Identity verification (Aadhaar/photo ID match against tabPatient); export as PDF; watermark; log the release
Legal representative with authorization letter	YES	Identity verification + retain authorization letter as a Frappe attachment; log the release
Spouse / family member without authorization	NO	Direct them to the patient; offer to log the request for the patient to action
Insurance company with patient's signed release	YES	Same as legal rep + retain signed release; log the release

- **Default action.** Treat as Confidential release. Always log via tabVersion + manual export-log row in a custom DocType PHI Release Log. Never email the PDF; require pickup or encrypted transfer.

Edge case 5 — Service account (e.g., nightly-backup) needs to be replaced

- **Trigger.** The container hosting nightly-backup is being retired. A new container with a new service account must take over.
- **Decision matrix.**

Action	Allowed?	Why
Create new service account with same scopes	YES	No elevation of privilege; same minimal permissions
Grant new account Frappe Administrator for "convenience"	NO	§3.1.3 — service accounts get minimum scope
Reuse the old account name on the new container	YES	Names are stable; the credential rotates
Keep the old container alive "just in case"	NO	§3.4 — retired assets get decommissioned, not archived

- **Default action.** New container, new credential, same name. Rotate DB password if the old credential was long-lived (> 1 year). Decommission old container.

Edge case 6 — Quarterly access review reveals a stale tabUser

- **Trigger.** During the Q3 2026 review, Venkat finds a tabUser for "Anita K." who left in 2025-Q4 and was never disabled.
- **Decision matrix.**

Action	Allowed?	Why
Disable the account + audit last 90 days of activity	YES	§3.4 Deprovisioning was missed; audit catches what data the stale account could have touched
Just delete the user	NO	Deletes audit trail; future investigation can't see what happened
Re-enable and ask the user to re-confirm	NO	The user left; this is a social-engineering attack vector

- **Default action.** Disable (do not delete), audit the last 90 days, document the missed-deprovisioning in the access register. Add a calendar reminder to review the offboarding checklist quarterly.

Edge case 7 — Two-factor device lost (e.g., phone with TOTP app)

- **Trigger.** A System Manager's phone is lost. TOTP codes are inaccessible.
- **Decision matrix.**

Action	Allowed?	Why
Use a backup TOTP code (single-use)	YES (per Frappe framework)	Standard recovery path
Venkat disables MFA + forces re-enrollment on next login	YES (admin recovery)	Recovery via admin is the framework-supported escape hatch
Shared TOTP secret over Slack to "fix it faster"	NO	Violates §3.2.2 — secrets in chat
Wait until the device is found	RISKY	If the device is compromised, attacker now has valid TOTP

- **Default action.** Use a backup TOTP code immediately. Then rotate the TOTP secret (Frappe framework supports this in user settings). Audit the last 24h of logins from that account while the device was potentially out of possession.

7. Related Documents

- 01-info-security.md — Umbrella policy.
- 03-asset-management.md — Data classification (drives role defaults).
- 04-cryptography.md — Secret storage + rotation.
- ../04-runbooks/04.4-incident-response.md — SEV-1 lockout / compromise response.
- ../../../../learnings/LEARNINGS.md — Lesson #154 (DB password drift).
- ../../../../MEMORY.md — Container naming + credential verification commands.

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial

Version	Date	Author	Changes
1.1	2026-08-29	venkat-narasimha	Added §3a Current State (full identity inventory + gaps), §3b Concrete Examples (6 incidents including #154, #153, #153-deploy-gate, #78 cron race, 2026-08-11 Roster delete, 2026-05-23 SSH key, 2026-08-15 git identity), §6a Edge Cases (7 scenarios with decision matrix).

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ☐ **Formalize docs/phase6/09-compliance/access-register.md** — every tabUser row, role assignment, last-review date, deprovisioning status. Source of truth for quarterly review. Owner: VN. Target: 2026-09-05. Status: Not Started.
- ☐ **TOTP-enroll PA on pberpprod** as System Manager (currently password-only on prod). Owner: PA. Target: 2026-09-05. Status: Not Started.
- ☐ **Verify current DB passwords** via `docker exec erp-{prod,dev,qa}-db-1 printenv MYSQL_ROOT_PASSWORD` and reconcile against access register. Owner: PA. Target: 2026-09-05. Status: Not Started.

Short-term (2026-Q3)

- ☐ **Provision per-nurse tabUser for all 6 front-desk nurses** with Employee + Nurse roles. Replace any shared shift accounts. Owner: VN. Target: 2026-09-30. Status: Not Started.
- ☐ **Configure Frappe idle-session timeout = 15 min / absolute = 8h** on all envs. Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Implement valid_upto field on tabHasRole** (custom field) so elevated roles can auto-expire. Owner: VN. Target: 2026-10-15. Status: Not Started.
- ☐ **Add a Front Desk Shift Coverage role profile** for floating-nurse coverage. Owner: VN. Target: 2026-09-30. Status: Not Started.
- ☐ **Document PHI release flow** (PHI Release Log DocType + identity-verification checklist). Owner: VN. Target: 2026-10-15. Status: Not Started.

Medium-term (2026-Q4)

- ☐ **MFA-enroll all Employee-role users** (currently password-only). Owner: PA. Target: 2026-11-15. Status: Not Started.

- ❑ **Enable MariaDB general_log** for a sliding 7-day window to audit haritha_ro queries. Owner: PA. Target: 2026-10-31. Status: Not Started.
- ❑ **Add a daily-ops heartbeat probe** for tabUser.enabled = 0 count (catches missed deprovisioning faster than quarterly review). Owner: PA. Target: 2026-10-15. Status: Not Started.
- ❑ **Add an offboarding checklist** that runs on personnel change (disable account, rotate password, remove SSH keys, revoke API tokens). Owner: VN. Target: 2026-10-31. Status: Not Started.

Long-term (2027+)

- ❑ **Integrate SCIM/SSO** with the future HRIS so user provisioning is automated. Owner: VN. Target: TBD. Status: Blocked (no HRIS yet).
- ❑ **Custom Frappe app for emergency-access logging** that integrates with tabHasRole audit + /var/log/erp-emergency-access.log. Owner: VN. Target: TBD. Status: Not Started.
- ❑ **Migrate haritha_ro to per-analyst accounts** (currently single read-only user shared across analysts). Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (runs forever)

- ❑ **Quarterly access review** (reconcile tabUser ↔ access register; disable stale accounts). Owner: VN. Frequency: quarterly. Status: In Progress.
- ❑ **Quarterly DB password re-verification** (LEARNINGS #154 pattern). Owner: PA. Frequency: quarterly. Status: Done.
- ❑ **Monthly failed-login review** (alert on >5 failures/day per account). Owner: PA. Frequency: monthly. Status: Done.
- ❑ **Annual SSH key rotation** (per §3.2.4; 7-day overlap). Owner: VN. Frequency: annually. Status: Done.
- ❑ **Annual API token rotation** (GitHub PATs, Frappe user tokens). Owner: VN. Frequency: annually. Status: Done.
- ❑ **Monthly review of tabHasRole for unexpected System Manager grants**. Owner: VN. Frequency: monthly. Status: In Progress.
- ❑ **Quarterly review of GitHub collaborators** (revoke stale invites). Owner: VN. Frequency: quarterly. Status: Done.